

Informe Pirámide del dolor.

La Pirámide del Dolor sigue siendo, en 2026, un marco incómodamente vigente: un recordatorio de que medir hashes es fácil, pero medir cuánto le duele de verdad a un adversario cambiar de TTP es otra liga, sobre todo si uno pretende hacerlo a escala país.¹²³

1. Recordatorio breve: qué mide realmente la Pirámide

Bianco no diseñó la Pirámide del Dolor para decorar presentaciones, sino como un modelo de uso efectivo de la inteligencia de amenazas en operaciones de detección, ordenando los indicadores por el coste que imponen al adversario cuando se detectan. Desde abajo hacia arriba (de “aspirina” a “cirugía abierta”) se sitúan: hashes, direcciones IP, dominios, artefactos de red/host, herramientas y, culminando, las TTP (tácticas, técnicas y procedimientos) alineadas hoy de forma casi inevitable con MITRE ATT&CK. La tendencia desde 2025 no es rehacer el modelo, sino densificarlo: indicadores de infraestructura efímera y automatizada en la base, y un esfuerzo cada vez más obsesivo en el vértice por capturar comportamiento reusable del adversario.⁴⁵⁶⁷⁸⁹¹⁰¹¹

2. Tendencias globales recientes por nivel de indicador (2025–2026)

La literatura y los informes industriales de estos años apuntan a una reinterpretación práctica: más que “seis peldaños”, la pirámide se usa como eje para métricas de coste y robustez, enlazando con iniciativas

1 <https://www.vectra.ai/topics/pyramid-of-pain>

2 <https://www.sans.org/tools/the-pyramid-of-pain>

3 <https://cybersecuritycompass.org/rethinking-the-pyramid-of-pain-in-2025-precision-pressure-and-the-power-of-context-de74384aacfe>

4 <https://cymulate.com/cybersecurity-glossary/pyramid-of-pain/>

5 <https://www.eccouncil.org/cybersecurity-exchange/threat-intelligence/pyramid-pain-threat-detection/>

6 <https://www.picussecurity.com/resource/glossary/what-is-pyramid-of-pain>

7 <https://www.vectra.ai/topics/pyramid-of-pain>

8 <https://www.sans.org/tools/the-pyramid-of-pain>

9 <https://cybersecuritycompass.org/rethinking-the-pyramid-of-pain-in-2025-precision-pressure-and-the-power-of-context-de74384aacfe>

10 <https://www.sans.org/tools/the-pyramid-of-pain>

11 <https://www.vectra.ai/topics/pyramid-of-pain>

como “Summiting the Pyramid” de MITRE Engenuity y su versión actualizada (v3.0) para medir la robustez analítica de detecciones.¹²¹³

En los niveles bajos (hashes, IPs, dominios), el consenso es que su valor principal es forense, de enriquecimiento y de automatización táctica, no de “dolor” sostenido al adversario. La rotación automática de infraestructura, malware polimórfico y la proliferación de kits “as-a-service” convierten las listas de indicadores en un deporte de reacción; la métrica clave ya no es el número de IoC bloqueados, sino su tiempo de vida útil, la velocidad de propagación a controles nacionales y el grado de correlación con artefactos superiores de la pirámide.¹⁴¹⁵¹⁶¹⁷¹⁸¹⁹

En los niveles intermedios (artefactos de red y host), los informes recientes insisten en que aquí es donde se empieza a ganar dinero de verdad: patrones de tráfico, firmas de protocolos anómalos, trazas en EDR/XDR y combinaciones de eventos que, aunque el adversario cambie de IP o de hash, siguen persiguiendo su forma de moverse. Se habla de “piramidizar” las reglas de SIEM/XDR: etiquetar cada detección con su nivel de la Pirámide para poder medir, en frío, cuánto esfuerzo se dedica a hacerle daño donde más le cuesta cambiar.²⁰²¹²²²³

En la cúspide, TTP y herramientas, la moda no es moda: los SOC que reordenan su estrategia de detección para priorizar contenidos mapeados a TTP reportan reducciones significativas de ataques exitosos (del orden del 50–60% cuando se privilegia detección por comportamiento sobre indicadores triviales) y caídas importantes en falsos positivos y tiempo de respuesta. MITRE ATT&CK se usa como

12 <https://www.sans.org/tools/the-pyramid-of-pain>

13 <https://www.shadecoder.com/topics/pyramid-of-pain-a-comprehensive-guide-for-2025>

14 <https://www.eccouncil.org/cybersecurity-exchange/threat-intelligence/pyramid-pain-threat-detection/>

15 <https://www.vectra.ai/topics/pyramid-of-pain>

16 <https://www.vectra.ai/topics/pyramid-of-pain>

17 <https://www.sans.org/tools/the-pyramid-of-pain>

18 <https://www.vectra.ai/topics/pyramid-of-pain>

19 <https://www.sans.org/tools/the-pyramid-of-pain>

20 <https://www.vectra.ai/topics/pyramid-of-pain>

21 <https://cybersecuritycompass.org/rethinking-the-pyramid-of-pain-in-2025-precision-pressure-and-the-power-of-context-de74384aacfe>

22 <https://www.eccouncil.org/cybersecurity-exchange/threat-intelligence/pyramid-pain-threat-detection/>

23 <https://www.sans.org/tools/the-pyramid-of-pain>

“gramática” para estos indicadores: se mide cobertura de técnicas críticas, robustez analítica y coste operativo estimado que se impone al atacante al bloquear conjuntos coherentes de técnicas.²⁴²⁵²⁶

3. De modelo conceptual a sistema de métricas: qué indicadores usar

La gran mutación post-2025 no es conceptual sino metrológica: la Pirámide del Dolor deja de ser un póster y se convierte en un eje explícito de medición, con indicadores asociados a cada nivel. A escala organizativa y, por extensión, nacional, aparecen patrones relativamente convergentes:²⁷²⁸²⁹³⁰

- En la base, indicadores como número de IoC procesados por día, time-to-distribute desde fuentes nacionales o sectoriales, tasa de reutilización de IoC en incidentes y tiempo medio de vida antes de volverse inútiles. La métrica honesta aquí es: ¿cuánto tardamos en compartir un hash que, cuando llega a la pyme de provincia, ya ha sido abandonado por el adversario?¹⁰²
- En el estrato de artefactos, indicadores orientados a calidad y contexto: cantidad de detecciones basadas en patrones de tráfico y host, tasa de falsos positivos de esas reglas, y, más interesante, porcentaje de incidentes críticos donde se generó al menos una alerta de artefacto antes del impacto. Es la versión cuantificada de la pregunta incómoda: “¿Nuestros sensores vieron algo útil antes de que se cifraran los servidores?”.¹¹⁵²
- Para herramientas y TTP, las métricas de “dolor”, más alineadas con el espíritu original de Bianco, incluyen distribución de reglas por nivel de la pirámide, tiempo medio para desarrollar detecciones frente a nuevas TTP observadas, cobertura ATT\&CK de técnicas usadas en campañas relevantes, reducción de dwell time asociada a detecciones de nivel alto y, a nivel agregado, reducción porcentual de ataques exitosos cuando se hace pivot a detección por comportamiento. La industria empieza incluso a monetizar el dolor del adversario: se estiman ahorros anuales por analista gracias a la mejora de calidad de las detecciones (decenas de miles de dólares por profesional, según algunos proveedores) cuando se priorizan reglas de alto nivel.⁵²³

²⁴ <https://www.shadecoder.com/topics/pyramid-of-pain-a-comprehensive-guide-for-2025>

²⁵ <https://www.eccouncil.org/cybersecurity-exchange/threat-intelligence/pyramid-pain-threat-detection/>

²⁶ <https://cybersecuritycompass.org/rethinking-the-pyramid-of-pain-in-2025-precision-pressure-and-the-power-of-context-de74384aacfe>

²⁷ <https://cybersecuritycompass.org/rethinking-the-pyramid-of-pain-in-2025-precision-pressure-and-the-power-of-context-de74384aacfe>

²⁸ https://netlas.io/blog/pyramid_of_pain/

²⁹ <https://www.eccouncil.org/cybersecurity-exchange/threat-intelligence/pyramid-pain-threat-detection/>

³⁰ <https://www.sans.org/tools/the-pyramid-of-pain>

En este contexto, la propuesta implícita es clara: los indicadores medidos dejan de ser “cuántos IOC hemos bloqueado” y pasan a ser “qué proporción de nuestra inversión en detección se dirige a capas de la pirámide cuya modificación cuesta tiempo, talento y dinero al atacante”.³¹³²

4. Aplicación a escala nacional: el caso español en contexto europeo y global

España llega a 2025 con cifras de ciberincidentes en constante crecimiento, con más de 97.000 incidentes gestionados por el INCIBE en 2024, un aumento superior al 16% respecto al año anterior, y con una mayoría de casos afectando a ciudadanos y pymes. Los ataques de mayor gravedad detectados a nivel nacional superan los 100.000 en 2024, con un incidente muy grave aproximadamente cada tres días según datos oficiales del Gobierno. Todo ello en un contexto europeo en el que ENISA describe un ecosistema de amenazas industrializadas, con una mayoría de incidentes ligados a ransomware y brechas de datos, y un aumento notable de ataques a tecnología operacional y sectores industriales.³³³⁴³⁵³⁶³⁷

Las estrategias nacionales —España con su Estrategia de Ciberseguridad y el Plan Nacional de Ciberseguridad, la Unión Europea con su informe sobre el estado de la ciberseguridad, y los marcos internacionales como el Índice Global de Ciberseguridad de la UIT— apuntan a la necesidad de incluir indicadores de desempeño claros, revisables, que permitan monitorizar la implementación de capacidades y la resiliencia de servicios esenciales. Lo que suelen medir, sin embargo, son variables de madurez normativa, existencia de planes y capacidades institucionales, no la estructura “piramidal” de las detecciones que esos planes generan.³⁸³⁹⁴⁰⁴¹⁴²

31 <https://www.sans.org/tools/the-pyramid-of-pain>

32 <https://www.sans.org/tools/the-pyramid-of-pain>

33 https://netlas.io/blog/pyramid_of_pain/

34 <https://www.eccouncil.org/cybersecurity-exchange/threat-intelligence/pyramid-pain-threat-detection/>

35 <https://www.picussecurity.com/resource/glossary/what-is-pyramid-of-pain>

36 <https://www.plixer.com/blog/indicators-of-compromise-guide/>

37 <https://www.vectra.ai/topics/pyramid-of-pain>

38 <https://www.picussecurity.com/resource/glossary/what-is-pyramid-of-pain>

39 <https://cymulate.com/cybersecurity-glossary/pyramid-of-pain/>

40 <https://www.vectra.ai/topics/pyramid-of-pain>

41 <https://www.shadecoder.com/topics/pyramid-of-pain-a-comprehensive-guide-for-2025>

42 <https://www.sans.org/tools/the-pyramid-of-pain>

Aquí la Pirámide del Dolor propone un correctivo saludable: si a nivel país sólo contamos incidentes gestionados, tiempos de respuesta y número de campañas bloqueadas, nos quedamos en una estadística de superficie. La pregunta “bianciana” sería: ¿cuánto de lo que hacemos en España causa realmente fricción estructural a los adversarios que nos atacan, y cuánto es mero barrido de migas (IPs, hashes, dominios descartables)?⁴³⁴⁴⁴⁵⁴⁶⁴⁷

En comparación, algunos marcos internacionales empiezan a incorporar de forma más explícita la lógica de la pirámide en evaluaciones nacionales: índices que valoran no sólo la existencia de capacidades técnicas, sino su grado de orientación a detección basada en comportamiento y TTP, también en el ámbito público. España figura en buenas posiciones en índices de ciberseguridad y digitalización, pero los informes sectoriales muestran una exposición persistente de sistemas vulnerables, con centenares de miles de activos detectados como vulnerables en 2024, lo que sugiere una brecha entre madurez declarada y práctica de hardening y detección avanzada.⁴⁸⁴⁹⁵⁰⁵¹⁵²

5. Propuesta de indicadores “pirámide-centrados” para España

Si uno toma en serio la premisa de actuar a escala territorial, hay que pensar en indicadores que puedan agregarse desde múltiples dominios (sector público, operadores críticos, pymes, ciudadanos) sin traicionar la esencia del modelo. A partir de las tendencias globales y las prácticas de medición emergentes, pueden delinearse al menos cuatro planos de indicadores.⁵³⁵⁴

43 <https://www.vectra.ai/topics/pyramid-of-pain>

44 <https://www.slideshare.net/slideshow/mitre-attckcon-2018-summitting-the-pyramid-of-pain-operationalizing-attck-emma-macmullan-and-justin-sherenco-general-electric/123180361>

45 <https://www.sans.org/tools/the-pyramid-of-pain>

46 <https://www.plixer.com/blog/indicators-of-compromise-guide/>

47 <https://www.eccouncil.org/cybersecurity-exchange/threat-intelligence/pyramid-pain-threat-detection/>

48 https://netlas.io/blog/pyramid_of_pain/

49 <https://www.picussecurity.com/resource/glossary/what-is-pyramid-of-pain>

50 <https://www.digitalsme.eu/enisa-cybersecurity-threat-landscape-report-2025-key-takeaways-for-smes/>

51 https://digital.gob.es/en/comunicacion/notas-prensa/mtdfp/2025/05/2025-05-06_02

52 <https://www.shadecoder.com/topics/pyramid-of-pain-a-comprehensive-guide-for-2025>

53 <https://www.picussecurity.com/resource/glossary/what-is-pyramid-of-pain>

54 <https://cybersecuritycompass.org/rethinking-the-pyramid-of-pain-in-2025-precision-pressure-and-the-power-of-context-de74384aacfe>

En primer lugar, un plano de volumen y velocidad de IoC de bajo nivel: no para presumir de actividad, sino para medir la vida media de los indicadores y su tiempo de distribución desde fuentes centrales como el INCIBE hacia los distintos actores. Se trataría de medir, por ejemplo, la mediana de tiempo entre la detección inicial de un dominio malicioso en un CERT nacional o sectorial y su bloqueo efectivo en los principales proveedores y operadores de servicios críticos.⁵⁵⁵⁶⁵⁷

En segundo lugar, un plano de calidad de detecciones de artefactos de red y host, donde los indicadores nacionales respondan a preguntas como: en qué proporción de los incidentes críticos (por ejemplo, ransomware en hospitales) hubo alertas previas basadas en patrones de comportamiento de red u host, y con qué antelación media. Ello exigiría, claro, una homogeneización mínima de taxonomías y la voluntad política de reportar algo más que el número bruto de incidentes.⁵⁸⁵⁹⁶⁰

En tercer lugar, un plano de madurez en herramientas y TTP, donde los indicadores se apoyen explícitamente en MITRE ATT&CK: porcentaje de organismos y operadores críticos que mantienen matrices ATT&CK actualizadas con sus detecciones, grado de cobertura de técnicas prioritarias para los vectores más comunes en España, y ritmo de actualización de esas coberturas según los informes de amenazas en la UE. Este plano se alinea con la tendencia de MITRE Engenuity a evaluar la robustez analítica y con los informes de ENISA que enumeran vectores preferentes como phishing, explotación de vulnerabilidades y compromisos de cadena de suministro.⁶¹⁶²⁶³⁶⁴⁶⁵⁶⁶

55 <https://www.apolocybersecurity.com/en/blog-posts/espana-supera-los-97-000-incidentes-de-ciberseguridad-en-2024-ha-llegado-la-hora-del-ciberseguro>

56 <https://cymulate.com/cybersecurity-glossary/pyramid-of-pain/>

57 https://netlas.io/blog/pyramid_of_pain/

58 <https://www.plixer.com/blog/indicators-of-compromise-guide/>

59 <https://www.picussecurity.com/resource/glossary/what-is-pyramid-of-pain>

60 <https://www.vectra.ai/topics/pyramid-of-pain>

61 https://netlas.io/blog/pyramid_of_pain/

62 <https://www.shadecoder.com/topics/pyramid-of-pain-a-comprehensive-guide-for-2025>

63 <https://cybersecuritycompass.org/rethinking-the-pyramid-of-pain-in-2025-precision-pressure-and-the-power-of-context-de74384aacf>

64 <https://www.enisa.europa.eu/publications/enisa-threat-landscape-2025>

65 <https://www.vectra.ai/topics/pyramid-of-pain>

66 <https://blog.denexus.io/resources/enisa-threat-landscape-2025-ot-attacks-industrial-cybersecurity-crisis>

En cuarto lugar, un plano de eficacia y coste, que tome prestadas las métricas que algunos proveedores usan internamente: reducción de ataques exitosos atribuible a detecciones de alto nivel, disminución de tiempos de respuesta y falsos positivos al priorizar reglas de TTP, y estimaciones de ahorro de recursos humanos para los SOC nacionales y sectoriales. No se trata sólo de saber si el adversario siente dolor, sino de comprobar que el sistema sanitario —esto es, los equipos de seguridad— no se desangran investigando alertas frívolas.⁶⁷⁶⁸⁶⁹

Esta arquitectura de indicadores permitiría, a nivel país, comparar el perfil español con el de otros Estados miembros, usando la misma gramática de la pirámide: qué parte del esfuerzo nacional se queda atrapada abajo (IoC intercambiables) y qué parte se invierte en construir detecciones que obligan al adversario a reescribir manuales.⁷⁰⁷¹⁷²

6. Consideraciones filosóficas y de gobernanza: dolor para quién, medido por quién

Hay un componente inevitablemente filosófico en la empresa: un marco que habla de “dolor” invita a preguntarse quién lo cuantifica y desde qué perspectiva. A nivel nacional, el riesgo es doble: por un lado, convertir la Pirámide en un simple checklist (¿tenemos TTP? sí/no) que confunde la presencia de un gráfico en la estrategia con la existencia de capacidades reales; por otro, usar el lenguaje del “dolor al adversario” como coartada para políticas de vigilancia intrusivas, sin someter a escrutinio los efectos colaterales sobre derechos y confianza digital.⁷³⁷⁴⁷⁵⁷⁶

La literatura institucional reciente en la UE insiste en la necesidad de enfoques basados en evidencias y en la contextualización de los datos de amenazas, alertando contra lecturas simplistas de cifras de incidentes o rankings de ciberseguridad. Integrar la Pirámide del Dolor en la caja de herramientas nacional requiere, por tanto, algo más que entusiasmo técnico: implica definir claramente qué métricas se publican, cuáles se comparten de forma reservada entre operadores, y cómo se evitan incentivos

67 <https://www.sans.org/tools/the-pyramid-of-pain>

68 <https://ncsi.ega.ee/country/es/>

69 <https://www.sans.org/tools/the-pyramid-of-pain>

70 <https://depp.oecd.org/policies/ESP2475>

71 <https://www.picussecurity.com/resource/glossary/what-is-pyramid-of-pain>

72 <https://dig.watch/resource/spains-national-cybersecurity-strategy>

73 <https://www.vectra.ai/topics/pyramid-of-pain>

74 https://netlas.io/blog/pyramid_of_pain/

75 <https://www.sans.org/tools/the-pyramid-of-pain>

76 https://www.itu.int/en/ITU-D/Cybersecurity/Documents/GCIv5/2401416_1b_Global-Cybersecurity-Index-E.pdf

perversos (por ejemplo, inflar el número de detecciones de alto nivel a costa de recalificar reglas triviales).⁷⁷⁷⁸⁷⁹

España, en tanto que Estado miembro inmerso en iniciativas europeas de ciberresiliencia y con un tejido económico muy expuesto como muestran los informes sobre amenazas al sector público y a las pymes, está bien situada para utilizar la Pirámide como elemento estructurante de sus métricas, siempre que se adopte una lectura exigente: menos contabilidad de hashes, más auditorías de comportamiento adversario bloqueado.⁸⁰⁸¹⁸²⁸³⁸⁴

232425262728

⁷⁷ <https://www.picussecurity.com/resource/glossary/what-is-pyramid-of-pain>

⁷⁸ <https://www.picussecurity.com/resource/glossary/what-is-pyramid-of-pain>

⁷⁹ <https://www.sans.org/tools/the-pyramid-of-pain>

⁸⁰ <https://cymulate.com/cybersecurity-glossary/pyramid-of-pain/>

⁸¹ <https://www.vectra.ai/topics/pyramid-of-pain>

⁸² [https://www.enisa.europa.eu/sites/default/files/2024-11/2024 Report on the State of Cybersecurity in the Union - Condensed version.pdf](https://www.enisa.europa.eu/sites/default/files/2024-11/2024_Report_on_the_State_of_Cybersecurity_in_the_Union_-_Condensed_version.pdf)

⁸³ <https://industrialcyber.co/reports/enisa-2025-threat-landscape-report-highlights-eu-faces-escalating-hackivist-attacks-and-state-aligned-cyber-threats/>

⁸⁴ https://www.derechosdigitales.org/wp-content/uploads/DD_CYRILLA_ENG_2024pdf.pdf